

UNIVERSIDAD MARIANO GÁLVEZ DE GUATEMALA

FACULTAD DE INGENIERÍA EN SISTEMAS DE INFORMACIÓN

MAESTRÍA EN SEGURIDAD INFORMÁTICA

TAREA 3 - REDISEÑO SEGURO

Rediseño seguro de FinanciaWeb aplicando OWASP ASVS

Autor (es):

Gerbert David García Loaiza - ggarcial17@miumg.edu.gt

Carné: 1293-21-11608

Profesor

Ing. Mario Roberto López Sajquin

Curso

SEGURIDAD EN APLICACIONES - 42026-1293-013-E

Guatemala, octubre de 2026

Tabla de Contenido

Introducción 1
1. Perfil de seguridad de FinanciaWeb 2
2. Problemas de diseño identificados 2
3. Rediseño de la arquitectura 3
3.1 Arquitectura actual 3
3.2 Arquitectura propuesta 4
4. Principios de desarrollo seguro 5
5. Aplicación de OWASP ASVS 6
6. Cinco decisiones críticas de arquitectura 7
7. Escenario de ataque: acceso a la cuenta de otro cliente 7
8. Respuesta ejecutiva 8
Referencias 9

Introducción

Este documento presenta el rediseño seguro de FinanciaWeb, la aplicación de banca en línea del caso de estudio de la Tarea 3. El análisis asume el rol de Arquitecto de Seguridad de Aplicaciones: parte del perfil de riesgo del sistema, explica por qué las decisiones actuales son inseguras y propone una arquitectura donde cada componente responde a un riesgo identificado.

El trabajo evita la lista de vulnerabilidades. Cada decisión se relaciona con un principio de diseño seguro, un requisito del Estándar de Verificación de Seguridad de Aplicaciones de OWASP (ASVS) y una forma concreta de comprobar que el control funciona. Se utilizó la versión 5.0.0 de ASVS (OWASP Foundation, 2025).

1. Perfil de seguridad de FinanciaWeb

El perfil se construyó antes de proponer controles, con la información del caso y los resultados de la revisión de seguridad. La Tabla 1 resume qué se protege, de quién, con qué impacto y qué nivel de aseguramiento requiere.

Tabla 1

Perfil de seguridad de FinanciaWeb

Elemento	Análisis
Tipo de aplicación	Aplicación web de banca en línea con interfaz de una sola página y una API REST. El diagrama del caso menciona también un cliente móvil que consume la misma API.
Usuarios	Clientes (externos, anónimos hasta que se autentican), administradores (internos, con privilegios altos), operadores o personal de soporte (supuesto, no descrito en el caso), servicios internos como la base de datos y la generación de PDF, y atacantes automatizados, como los que dejaron intentos masivos de inicio de sesión.
Información procesada	Credenciales (usuario y contraseña con SHA-256), datos personales (correo y teléfono), saldos y movimientos, cuentas de terceros registradas, transferencias, estados de cuenta en PDF, tokens de sesión y registros de inicio de sesión.
Operaciones críticas	Transferencias, registro de cuentas de terceros, recuperación de contraseña, cambio de correo y teléfono (permite tomar una cuenta), descarga de estados de cuenta y funciones administrativas.
Exposición	Internet de forma directa: la API no tiene una capa intermedia. Frontend y backend comparten servidor y el backend usa una sola cuenta de base de datos. No se describen integraciones con terceros.
Impacto	Confidencialidad alta: datos financieros y personales, y ya se comprobó que un cliente vio información de otro. Integridad alta: se pueden alterar transferencias, cuentas de terceros y datos de contacto. Disponibilidad media: un servidor único y una API abierta facilitan el abuso automatizado, y el canal es importante para el negocio.
Criticidad	Alta. El impacto sobre la confidencialidad y la integridad es grave y ya existe una vulnerabilidad explotada, pero se trata de un canal de operaciones básicas y no de una infraestructura financiera sistémica. La administración y las transferencias se tratan con criticidad crítica.
Nivel ASVS propuesto	Nivel 2, con requisitos puntuales de Nivel 3 en la administración. La justificación se desarrolla después de la tabla.

Nota. Elaboración propia con base en el caso de estudio (Dirección de Posgrados FISI, 2026).

ASVS 5.0 define el Nivel 1 como el primer paso de adopción, el Nivel 2 como una visión completa de las prácticas estándar de seguridad y el Nivel 3 como requisitos avanzados de alta garantía (OWASP Foundation, 2025). FinanciaWeb maneja credenciales, datos personales y financieros y ejecuta transferencias, por lo que el Nivel 1 se queda corto: no exige, por ejemplo, la clasificación de datos, el registro detallado de eventos ni la gestión de secretos. Se propone el Nivel 2 como base. Los requisitos de Nivel 3 se limitan a la administración (V8.4.2), porque el compromiso de una cuenta administrativa expone a todos los clientes. Un Nivel 3 completo exigiría, entre otros controles, factores de hardware para todos los usuarios, cuyo costo no se justifica para un canal de operaciones básicas.

2. Problemas de diseño identificados

Los diez problemas de la Tabla 2 parten de los resultados de la revisión (sección 3.4 del caso) y de las decisiones actuales (sección 3.3). Cada fila explica por qué la decisión de diseño es insegura, y no solo el nombre de la vulnerabilidad. Los riesgos usan la terminología de OWASP API Security Top 10: autorización rota a nivel de objeto (API1), autenticación rota (API2) y autorización rota a nivel de función (API5) (OWASP Foundation, 2023). Los números P1 a P10 se usan en los diagramas y en las matrices posteriores.

Tabla 2

Problemas de diseño de la arquitectura actual

ID	Problema identificado	Riesgo	Posible impacto	Componente afectado
P1	Los identificadores de cuenta viajan en la URL y el backend los acepta sin comprobar que pertenezcan al usuario autenticado. La decisión de diseño deja la propiedad del dato en manos de quien conoce el identificador y no del servidor (hallazgo 1).	Autorización rota a nivel de objeto: un cliente autenticado consulta o altera recursos de otro.	Pérdida de confidencialidad de saldos y movimientos de cualquier cliente y posible alteración de datos. Ya se demostró en la revisión.	API REST y backend
P2	Los permisos se validan principalmente en el frontend y algunos endpoints solo comprueban la interfaz web (hallazgos 6 y 7). Un control que vive en el cliente se evita mediante llamadas directas a la API, sin pasar por la interfaz.	Autorización rota a nivel de función: elevación de privilegios.	Un cliente podría ejecutar funciones de otros roles, incluidas las administrativas.	Frontend y API REST
P3	La autenticación depende solo de usuario y contraseña, sin límite de intentos ni respuesta adaptativa. Los intentos automatizados observados (hallazgo 2) no encuentran fricción.	Relleno de credenciales y fuerza bruta: toma de cuentas.	Acceso no autorizado a cuentas y transferencias fraudulentas.	Inicio de sesión y API REST
P4	Las contraseñas se almacenan con SHA-256, una función rápida de propósito general que no se diseñó para proteger contraseñas, y el caso no indica el uso de sal.	Descifrado por fuerza bruta fuera de línea si se filtra la base de datos.	Reutilización masiva de las credenciales de los clientes en esta y en otras aplicaciones.	Base de datos y autenticación
P5	Una sesión puede permanecer abierta indefinidamente y los tokens siguen válidos tras cambiar la contraseña (hallazgo 3). La caducidad y la revocación no forman parte del diseño de las sesiones.	Robo y reutilización de sesión; el atacante conserva el acceso después de la recuperación de la cuenta.	El cliente que cambia su contraseña por sospecha de robo sigue expuesto; las sesiones abandonadas quedan disponibles en equipos compartidos.	Gestión de sesiones y tokens
P6	Administradores y clientes usan el mismo mecanismo de autenticación (hallazgo 6). No hay canal separado ni factor adicional para funciones de alto privilegio.	Compromiso de una cuenta administrativa con el mismo esfuerzo que una cuenta de cliente.	Control de los datos de todos los clientes y cambios críticos sin atribución.	Autenticación y panel administrativo
P7	La API se consume directamente desde Internet, sin una capa que filtre el tráfico, valide la forma de los datos ni limite el uso. Además acepta valores inesperados en algunos endpoints y devuelve errores con nombres de tablas y componentes (hallazgos 4 y 5).	Inyección y manipulación de parámetros, abuso automatizado y divulgación de información que facilita el ataque.	Alteración de datos, mapeo de la base de datos por el atacante y agotamiento de recursos.	API REST (exposición)
P8	Frontend y backend comparten servidor y el backend usa una única cuenta de base de datos con permisos de lectura, escritura y administración. No hay segmentación ni límites de privilegio: una falla en una capa expone todas.	Movimiento lateral y escalamiento total ante un solo compromiso, como una inyección.	Pérdida total de confidencialidad, integridad y disponibilidad de la base de datos.	Servidor de aplicación y cuenta de base de datos
P9	Los PDF de estados de cuenta quedan disponibles de forma temporal en una URL. No consta que el acceso exija sesión ni que la URL sea de un solo uso, por lo que el control depende de que nadie la conozca (hallazgo 8).	Exposición de documentos financieros por una URL adivinable, reenviada o guardada en historiales y registros.	Fuga de información financiera sensible de los clientes.	Servicio de generación y almacenamiento de PDF
P10	Solo se registran los inicios de sesión: nadie sabe quién modifica información crítica (hallazgo 9). Además no hay requisitos de seguridad, modelado de amenazas ni clasificación de datos (hallazgo 10), de modo que los controles se deciden por urgencia.	Falta de trazabilidad y de gobierno de la seguridad: los incidentes no se detectan.	No se pueden atribuir cambios, atender auditorías ni priorizar controles.	Registro de auditoría y proceso de desarrollo

Nota. Los hallazgos corresponden a la sección 3.4 del caso. Elaboración propia.

3. Rediseño de la arquitectura

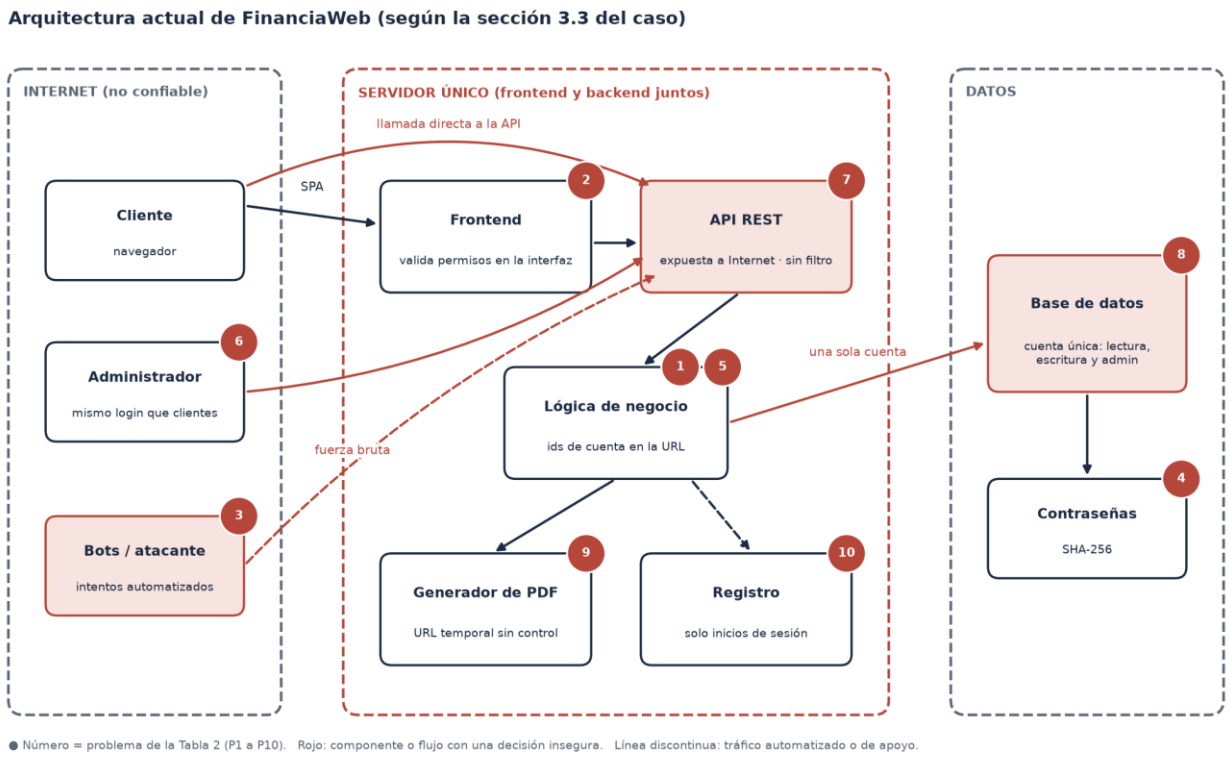
3.1 Arquitectura actual

La Figura 1 muestra la arquitectura que se deduce de la sección 3.3: el navegador llama a una API REST expuesta, frontend y backend comparten servidor, la lógica de negocio usa una

única cuenta de base de datos con todos los permisos y el registro cubre solo los inicios de sesión. Las insignias numeradas indican qué problema de la Tabla 2 afecta a cada componente.

Figura 1

Arquitectura actual de FinanciaWeb

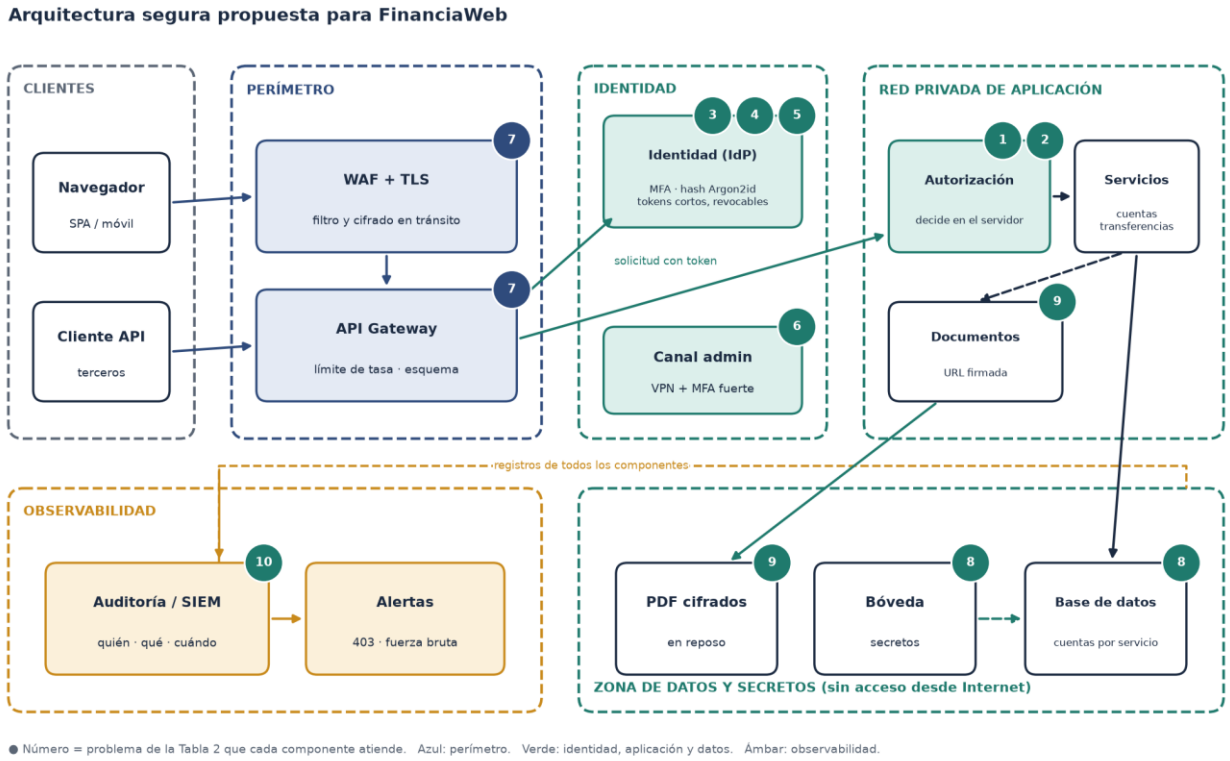


Nota. Elaboración propia con base en la sección 3.3 del caso.

3.2 Arquitectura propuesta

La Figura 2 presenta la arquitectura propuesta. Cada componente responde a un problema de la Tabla 2: el WAF y el API Gateway atienden P7 (exposición, validación y errores); el proveedor de identidad atiende P3, P4 y P5 (autenticación, contraseñas y sesiones); el canal administrativo separado atiende P6; el servicio de autorización atiende P1 y P2; el servicio de documentos con URL firmada y los PDF cifrados atienden P9; las cuentas de base de datos por servicio y la bóveda de secretos atienden P8, y la auditoría centralizada con alertas atiende P10. Los componentes se agrupan en zonas para que un compromiso en una no se extienda a las demás, lo que aplica la defensa en profundidad.

Figura 2
Arquitectura segura propuesta para FinanciaWeb



Nota. Los números indican el problema de la Tabla 2 que atiende cada componente. Elaboración propia.

4. Principios de desarrollo seguro

La Tabla 3 aplica siete principios de diseño seguro. Mínimo privilegio, seguro por defecto y mediación completa provienen del trabajo clásico de Saltzer y Schroeder (1975). Defensa en profundidad, fallo seguro, separación de responsabilidades y registro y trazabilidad completan los principios que se revisaron en clase (López Sajquin, 2026) y los que menciona el enunciado.

Tabla 3
Aplicación de principios de diseño seguro

Principio	Problema actual	Decisión de diseño propuesta	Beneficio
Mínimo privilegio	P8: el backend usa una cuenta de base de datos con permisos de lectura, escritura y administración.	Cuentas de servicio separadas por función, sin permisos de administración en ejecución, y roles de aplicación con permisos explícitos.	Reduce el impacto de un compromiso.
Defensa en profundidad	P7 y P3: solo la aplicación se defiende y una sola falla abre todo.	Capas sucesivas: WAF y gateway con límite de tasa y validación de esquema, proveedor de identidad con segundo factor, autorización en el servicio y controles en la base de datos.	Si una capa falla, la siguiente limita el ataque.
Seguro por defecto	P2: los permisos se validan en el frontend y lo que no se bloquea queda permitido.	Se niega todo salvo el permiso explícito concedido en el servidor; un endpoint nuevo nace cerrado hasta que se le asignan roles.	Una omisión del equipo no abre acceso.
Mediación completa	P1 y P2: algunos endpoints solo verifican la interfaz.	Toda petición pasa por un único punto de decisión que valida identidad, rol y propiedad del dato, sin rutas alternas ni decisiones guardadas en caché.	No existen caminos sin verificación y hay un solo lugar que auditar.
Fallo seguro	P7: los errores muestran nombres de tablas y componentes.	Ante un fallo de validación o de autorización se niega la acción, se responde con un mensaje genérico y un identificador de correlación y se genera una alerta.	Un error controlado no filtra información ni abre acceso.

Principio	Problema actual	Decisión de diseño propuesta	Beneficio
Separación de responsabilidades	P6: administradores y clientes comparten el mecanismo de autenticación.	Canal y proveedor de identidad administrativos aparte, con segundo factor fuerte; el personal de auditoría solo lee los registros y no puede alterarlos.	Ningún rol puede ejecutar una acción y encubrirla.
Registro y trazabilidad	P10: solo se registran los inicios de sesión.	Servicio de auditoría centralizado que registra quién, qué, cuándo y desde dónde en operaciones críticas, con almacenamiento de solo anexado y alertas.	Permite detectar, investigar y atribuir incidentes.

Nota. Elaboración propia.

5. Aplicación de OWASP ASVS

La Tabla 4 relaciona 12 requisitos de ASVS 5.0.0, de ocho capítulos, con los problemas de la Tabla 2. La lógica es: requisito, problema, decisión de arquitectura o desarrollo y mecanismo de verificación. El nivel de cada requisito es el que asigna el estándar. El requisito V8.4.2 es de Nivel 3 y se adopta solo para la administración, como se justificó en la sección 1.

Tabla 4

Matriz de requisitos de OWASP ASVS 5.0.0 aplicados a FinanciaWeb

Categoría	Requisito e ID	Problema encontrado	Decisión de diseño	Cómo se verificará
V8 Autorización	V8.2.2 (N1) El acceso a cada dato se restringe a quien tiene permiso explícito sobre ese dato.	P1: se ven datos de otro cliente al cambiar un identificador.	La API filtra cada consulta por el titular tomado del token y no de la URL; los identificadores dejan de ser secuenciales.	Pruebas automatizadas con dos clientes: A pide recursos de B y recibe 403 o 404; prueba de penetración enfocada en este tipo de fallo.
V8 Autorización	V8.3.1 (N1) Las reglas de autorización se aplican en una capa de servicio confiable y no en controles que el cliente pueda manipular.	P2: los permisos se validan en la interfaz web.	Política de autorización en el servidor; el frontend solo oculta opciones.	Llamar a cada endpoint con un token de rol inferior y sin la interfaz; revisión de código para detectar decisiones de acceso en el cliente.
V6 Autenticación	V6.3.1 (N1) Se implementan controles contra el relleno de credenciales y la fuerza bruta.	P3: los intentos automatizados no encuentran límite.	Límite de intentos por cuenta y por origen, retardo progresivo, bloqueo temporal y aviso al titular.	Prueba que supera el umbral de intentos fallidos y comprueba el bloqueo; la alerta aparece en el monitoreo.
V6 Autenticación	V6.3.3 (N2) Se exige un mecanismo de autenticación multifactor o una combinación de factores simples.	P3 y P6: la autenticación depende solo de la contraseña.	Segundo factor obligatorio en el proveedor de identidad para clientes en operaciones sensibles y para administradores.	Un inicio de sesión sin segundo factor es rechazado; revisión de la configuración del proveedor de identidad.
V11 Criptografía	V11.4.2 (N2) Las contraseñas se almacenan con una función de derivación de claves aprobada y computacionalmente intensiva.	P4: contraseñas con SHA-256.	Migrar a Argon2id (o una alternativa aprobada) con parámetros según la guía vigente y regenerar el hash en el siguiente inicio de sesión.	Revisión del formato de almacenamiento; consulta que confirma que no quedan hashes SHA-256 al terminar la migración.
V7 Sesiones	V7.4.3 (N2) Tras cambiar o recuperar un factor de autenticación se ofrece terminar las demás sesiones activas.	P5: los tokens siguen válidos después de cambiar la contraseña.	Revocar de forma automática todas las sesiones y tokens de renovación al cambiar la contraseña; tokens de acceso de vida corta.	Un token emitido antes del cambio de contraseña es rechazado; una sesión inactiva caduca en el tiempo definido.
V8 Autorización	V8.4.2 (N3) El acceso a las interfaces administrativas usa varias capas de seguridad y no depende de la ubicación de red.	P6: administradores y clientes comparten el mecanismo.	Panel administrativo en un segmento aparte, accesible por VPN o bastión con segundo factor fuerte y verificación de contexto.	El acceso al panel desde Internet falla; un intento con credenciales de cliente es rechazado; revisión de reglas de segmentación.
V2 Validación y lógica de negocio	V2.2.1 (N1) La entrada se valida contra una lista de valores, patrones y rangos permitidos.	P7: se aceptan valores inesperados en algunos endpoints.	Validación contra el esquema de la API en el gateway y de nuevo en el servicio; consultas parametrizadas.	Pruebas con valores fuera de rango y cargas malformadas que devuelven 400; prueba de fuzzing sobre los endpoints.
V16 Registro y errores	V16.5.1 (N2) Ante un error inesperado se devuelve un mensaje genérico, sin trazas, consultas ni datos internos.	P7: los errores muestran tablas y componentes.	Manejador global de errores: respuesta genérica con identificador de correlación; el detalle queda solo en el registro interno.	Provocar errores (identificador inválido, cuerpo roto) y verificar que la respuesta no contiene tablas, trazas ni nombres de componentes.
V13 Configuración	V13.2.2 (N2) La comunicación entre componentes del backend usa cuentas con los privilegios mínimos necesarios.	P8: una única cuenta de base de datos con todos los permisos.	Cuentas por servicio y por operación, sin administración en ejecución; credenciales en una bóveda de secretos (V13.3.1).	Revisión de los permisos de cada cuenta; el intento de alterar o borrar el esquema con la cuenta de la aplicación falla.

Categoría	Requisito e ID	Problema encontrado	Decisión de diseño	Cómo se verificará
V14 Protección de datos	V14.1.1 (N2) Los datos sensibles se identifican y clasifican en niveles de protección.	P9 y P10: no hay clasificación de datos y los PDF quedan en una URL.	Clasificación formal (público, interno, confidencial, restringido); los estados de cuenta se tratan como restringidos: cifrados en reposo y con URL firmada, de corta vida y ligada al titular.	Inventario documentado de datos; una URL vencida o de otro cliente responde 403 o 410; revisión de la retención de los PDF.
V16 Registro y errores	V16.2.1 (N2) Cada entrada de registro incluye los metadatos necesarios (cuándo, dónde, quién y qué) para investigar.	P10: no se registra quién modifica información crítica.	Auditoría centralizada de operaciones críticas y de administración, con almacenamiento de solo anexado; se registran también los rechazos de autorización (V16.3.2).	Un cambio de correo de un cliente genera un evento con los cuatro metadatos; varios rechazos seguidos generan una alerta.

Nota. Los requisitos se parafrasean a partir de OWASP Foundation (2025). N1, N2 y N3 indican el nivel ASVS del requisito.

6. Cinco decisiones críticas de arquitectura

Las cinco decisiones siguientes concentran la mayor reducción de riesgo. Se eligieron porque cada una atiende varios problemas de la Tabla 2 y porque, si una falla, las demás pierden efecto.

Tabla 5

Cinco decisiones críticas de arquitectura

Decisión	Problema que resuelve	Principio y requisito ASVS	Dónde se implementa	Cómo se demuestra
1. Autorización centralizada en el servidor, con verificación de propiedad del dato	P1 y P2: un cliente accede a datos ajenos al cambiar un identificador y algunos endpoints confían en la interfaz.	Mediación completa y seguro por defecto. ASVS V8.2.2 y V8.3.1.	Servicio de autorización en la red privada, invocado por todos los endpoints de la API. La identidad del titular se toma del token y no de la URL.	Pruebas automatizadas de la matriz rol por endpoint y del acceso entre dos clientes (A pide un recurso de B y recibe 403); el despliegue se bloquea si alguna falla.
2. Identidad centralizada con segundo factor, contraseñas con función de derivación y sesiones revocables	P3, P4 y P5: intentos masivos sin freno, contraseñas con SHA-256 y tokens que siguen vigentes tras cambiar la contraseña.	Defensa en profundidad. ASVS V6.3.1, V6.3.3, V11.4.2 y V7.4.3.	Proveedor de identidad estándar (OpenID Connect) fuera del backend de negocio; tokens de acceso de vida corta y revocación al cambiar o recuperar la contraseña.	Prueba de intentos repetidos que activa el límite; rechazo de un inicio de sesión sin segundo factor; un token emitido antes del cambio de contraseña es rechazado; no quedan hashes SHA-256.
3. API detrás de WAF y API Gateway, con frontend y backend en zonas separadas	P7 y P8: API expuesta sin filtro, valores inesperados, errores técnicos y un solo servidor.	Defensa en profundidad y fallo seguro. ASVS V2.2.1 y V16.5.1.	Perímetro de red con WAF, TLS y API Gateway que limita la tasa y valida contra el esquema de la API; el backend no tiene dirección pública; manejador global de errores.	Un escaneo desde Internet solo encuentra el gateway; los valores fuera de rango devuelven 400; los errores provocados muestran un mensaje genérico con identificador de correlación.
4. Mínimo privilegio en datos y secretos, y documentos con URL firmada de corta vida	P8 y P9: cuenta de base de datos con todos los permisos y estados de cuenta accesibles por una URL.	Mínimo privilegio. ASVS V13.2.2, V13.3.1 y V14.1.1.	Capa de datos con cuentas por servicio y por operación, bóveda de secretos y servicio de documentos con PDF cifrados.	Revisión de los permisos de cada cuenta; el intento de alterar el esquema con la cuenta de la aplicación falla; una URL vencida o de otro cliente responde 403; el repositorio no contiene secretos.
5. Auditoría centralizada y canal administrativo separado	P6 y P10: administradores con el mismo acceso que los clientes y ninguna trazabilidad de cambios críticos.	Separación de responsabilidades y registro y trazabilidad. ASVS V8.4.2, V16.2.1 y V16.3.2.	Servicio de auditoría (SIEM) con almacenamiento de solo anexado y alertas; panel administrativo en un segmento aparte, accesible por VPN con segundo factor fuerte.	Un cambio de correo de un cliente deja un evento con quién, qué, cuándo y desde dónde; el acceso al panel desde Internet falla; varios rechazos de autorización seguidos generan una alerta.

Nota. Elaboración propia.

7. Escenario de ataque: acceso a la cuenta de otro cliente

Se analiza el escenario «Acceso a la cuenta de otro cliente». Es el que la revisión de seguridad ya confirmó (hallazgo 1) y el que mejor muestra la defensa en profundidad, porque involucra autorización, automatización, sesiones, documentos y registro. La Tabla 6 compara cada etapa del ataque antes y después del rediseño e indica si el control impide, detecta o limita.

Tabla 6

Evolución del ataque antes y después del rediseño

Etapa	Antes del rediseño	Después del rediseño
1. Reconocimiento	El atacante usa una cuenta legítima y observa que las URL llevan el identificador de la cuenta.	Limita. Las URL no contienen el identificador del titular, que se toma del token, y los identificadores no son secuenciales.
2. Manipulación del identificador	Cambia el identificador en la URL y recibe saldos de otro cliente porque el backend no comprueba la propiedad.	Impide. El servicio de autorización verifica que el dato pertenece al titular (V8.2.2) y responde 403 o 404.
3. Automatización	Un script recorre identificadores consecutivos sin freno, porque la API está expuesta y no limita el uso.	Limita. El gateway restringe la tasa por cliente y por origen y la validación de esquema rechaza peticiones anómalas (V2.2.1).
4. Extracción de documentos	Descarga estados de cuenta en PDF de otros clientes a través de URL temporales sin control.	Impide. La URL es firmada, ligada al titular, de corta vida y de un solo uso; los PDF están cifrados en reposo (V14.1.1).
5. Persistencia y toma de la cuenta	Usa una sesión que no caduca y cambia el correo y el teléfono de la víctima; nadie registra quién modificó los datos.	Impide y detecta. El cambio de datos de contacto exige segundo factor, la sesión caduca y se revoca al cambiar la contraseña (V7.4.3), y la auditoría registra el cambio (V16.2.1).
6. Detección y respuesta	Solo existen registros de inicios de sesión, por lo que el incidente pasa inadvertido.	Detecta. Los rechazos de autorización quedan registrados (V16.3.2) y varios seguidos generan una alerta; el equipo revoca las sesiones del origen sospechoso.

Nota. Elaboración propia.

8. Respuesta ejecutiva

Corregir solo las vulnerabilidades encontradas no basta, porque la revisión mostró problemas de diseño y no errores aislados: la API no verifica a quién pertenece cada dato, los permisos viven en la interfaz, las sesiones no caducan y la base de datos usa una cuenta con todos los permisos. Un parche corrige el síntoma de un hallazgo, pero la causa, un control que nunca se definió, permanece y reaparece en el siguiente endpoint. Además, no se ha modelado ninguna amenaza ni se han clasificado los datos, por lo que otros defectos siguen sin detectarse.

Si solo se parchea, permanecen la exposición directa de la API, el almacenamiento débil de contraseñas, la ausencia de segundo factor, la falta de trazabilidad y el acceso administrativo común. Un incidente ocurriría sin que la empresa pudiera detectarlo ni reconstruirlo, con impacto financiero y de reputación. El riesgo ya se comprobó: un cliente vio información de otro.

Los controles añaden tiempo de desarrollo, pero corregir después de un incidente cuesta más. OWASP ASVS aporta requisitos verificables por nivel; permite decidir qué implementar sin discusiones subjetivas y demostrar con pruebas que cada control funciona. Se propone el Nivel 2 y una entrega por fases.

Condiciones obligatorias antes de publicar la nueva versión: (1) autorización en el servidor con verificación de propiedad (V8.2.2, V8.3.1); (2) segundo factor, límite de intentos y contraseñas con función de derivación (V6.3.1, V6.3.3, V11.4.2); (3) sesiones con caducidad y revocación (V7.4.3); (4) API detrás de un gateway, con validación y errores genéricos (V2.2.1, V16.5.1); (5) cuentas de base de datos con mínimo privilegio (V13.2.2); (6) registro de auditoría de las operaciones críticas (V16.2.1). El resto puede escalonarse.

Referencias

López Sajquin, M. R. (2026). *Diseño seguro: principios, patrones y arquitectura* [Clase grabada]. Seguridad en Aplicaciones (093-013), Maestría en Seguridad Informática, Universidad Mariano Gálvez de Guatemala.

OWASP Foundation. (2023). *OWASP API security top 10: 2023*. https://owasp.org/API-Security/editions/2023/en/0x11-t10/

OWASP Foundation. (2025). *OWASP application security verification standard* (Versión 5.0.0). https://owasp.org/www-project-application-security-verification-standard/

Saltzer, J. H., & Schroeder, M. D. (1975). The protection of information in computer systems. *Proceedings of the IEEE, 63*(9), 1278-1308. https://doi.org/10.1109/PROC.1975.9939